

ComplianceAI — Complete Project Description

THE PROBLEM

Every company that sells software to businesses eventually hears this:

"Send us your SOC 2 certificate or we can't sign the deal."

Compliance certification (SOC 2, ISO 27001, HIPAA) is mandatory for enterprise sales, fundraising, and handling customer data. But getting certified is brutal:

- **Time:** 6-12 months of manual work
- **Cost:** \$50K-\$200K (₹40 lakhs - ₹1.6 crores) in consulting fees
- **People:** Pulls 2-3 engineers away from product work for months
- **Process:** Writing policies, collecting evidence, filling spreadsheets, answering auditor questions — all done manually

The result: Startups delay compliance, lose enterprise deals, and fall behind competitors who got certified first.

WHAT COMPLIANCE ACTUALLY IS

Compliance = proving your company follows security rules.

Three major frameworks exist:

SOC 2 (Service Organization Control 2)

- Created by AICPA (American accounting body)
- Required by US enterprise buyers
- Checks: Is your tech infrastructure secure? Do you log activity? Do you encrypt data? Do you have incident response plans?
- 33 controls across 5 categories: Security, Availability, Processing Integrity, Confidentiality, Privacy

ISO 27001 (International Organization for Standardization)

- Global standard, especially for EU/international deals
- Checks: Do you have an Information Security Management System (ISMS)?
- 114 controls in Annex A covering everything from HR security to cryptography

HIPAA (Health Insurance Portability and Accountability Act)

- Required for anyone handling health data (patients, medical records)
- Checks: Is Protected Health Information (PHI) secure?
- Covers administrative, physical, and technical safeguards

The overlap: ~60% of these controls check the same thing. MFA requirement exists in all three. Encryption requirement exists in all three. Logging requirement exists in all three. But companies check them separately, paying 3x the cost and time.

WHAT THE PS REQUIRES US TO BUILD

The problem statement says: build an AI platform that takes organizations from **zero compliance documentation to audit-ready status**.

Specific requirements:

1. **Scan a sample AWS environment** — Connect to AWS infrastructure and read the actual security configuration
2. **Gap analysis for SOC 2** — Check every control and identify what's failing
3. **Gap analysis for ISO 27001 and HIPAA** — Same thing for the other two frameworks
4. **Auto-create at least 3 policies** — AI writes professional policy documents (Access Control Policy, Encryption Policy, Incident Response Policy)
5. **Collect evidence artifacts** — Automatically gather proof: CloudTrail logs (who did what), IAM configurations (who has access), encryption settings (is data protected)
6. **Audit-ready report** — Generate a PDF that an auditor could actually use
7. **Dashboard tracking progress** — Visual interface showing compliance status
8. **Continuous monitoring and drift detection** — Keep checking and alert if something changes (bonus points)

Technologies they want us to use:

- Amazon Bedrock (AI)
 - AWS Config (configuration tracking)
 - AWS CloudTrail (activity logging)
 - AWS Security Hub (security posture)
-

WHAT WE ARE BUILDING

Architecture (4 layers)

Layer 1 — Frontend (React) What the user sees and interacts with.

Pages:

- Landing page — explains the product
- Login — authentication
- Upload/Connect — user provides their AWS config
- Dashboard — shows results across all 3 frameworks
 - Controls tab — 33 checks with pass/fail, AI explanations, fix steps
 - Priority Fix tab — CES algorithm shows optimal fix order
 - Benchmark tab — compares against industry peers
 - Audit Prep tab — AI generates auditor questions with good/bad answers
 - Evidence tab — collected artifacts mapped to controls
 - Policies tab — AI-generated audit-ready documents
 - Drift tab — shows what changed since last scan
- PDF Export — downloadable audit report

Layer 2 — AI Reasoning (Amazon Bedrock) The AI brain that explains, generates, and advises.

Functions:

- Takes failed controls → explains WHY they're dangerous in plain English
- Generates step-by-step fix instructions for AWS console
- Writes 3 professional policy documents tailored to the company
- Generates realistic audit interview questions
- Powers the RAG compliance chatbot (answers questions using actual framework documents)

Layer 3 — Compliance Engine (Python) The rule-based brain that checks every control.

Contains:

- 33 SOC 2 control checks (if/else logic against AWS config)
- Cross-framework mapping (each check maps to SOC 2 + ISO 27001 + HIPAA control IDs)
- CES algorithm (calculates optimal fix priority)
- Industry benchmarks (compares score against 5 verticals)

Layer 4 — Evidence Collection (boto3/AWS SDK) Connects to actual AWS account and pulls live data.

Collects:

- CloudTrail logs (activity records)
 - IAM user list, MFA status, access keys
 - S3 bucket encryption and access settings
 - RDS backup and encryption status
 - Security Group rules (open ports)
 - VPC Flow Log status
 - GuardDuty/Security Hub findings
-

WHY CVSS DOESN'T SOLVE THIS PROBLEM

CVSS (Common Vulnerability Scoring System) is the industry standard for rating security vulnerabilities. It's been around since 2005. Every security scanner uses it.

What CVSS does:

Input: A specific vulnerability (e.g., "SQL injection in login form")

Output: A score from 0-10 (e.g., 9.8 CRITICAL)

Formula: $\text{BaseScore} \times \text{TemporalScore} \times \text{EnvironmentalScore}$

Why CVSS doesn't work for compliance:

Problem 1 — CVSS scores individual bugs, not compliance gaps

CVSS was designed for CVEs (Common Vulnerabilities and Exposures) — known software bugs. It answers: "How dangerous is this one bug?"

Compliance gaps are different. "MFA is not enabled" is not a bug — it's a missing configuration. "No incident response plan" is not a vulnerability — it's a missing document. CVSS has no way to score these.

Problem 2 — CVSS doesn't prioritize across multiple gaps

When you have 28 failing controls, CVSS can score each one individually. But it can't tell you: "Fix these 5 in this order to get the maximum compliance improvement." It treats each gap independently.

Real scenario: You have 28 gaps, 2 weeks before audit, limited budget. CVSS says "all 12 critical items are equally urgent." That's useless — you need to know WHICH critical items to fix first.

Problem 3 — CVSS doesn't understand framework relationships

CVSS doesn't know that fixing MFA satisfies SOC 2 CC6.1 AND ISO 27001 A.9.4.2 AND HIPAA §164.312(d). It scores each in isolation. So you might fix 3 separate things when 1 fix could have covered all three frameworks.

Problem 4 — CVSS doesn't factor in fix effort

Two gaps might both score 9.0 in CVSS. But one takes 5 minutes to fix (enable MFA) and the other takes 2 weeks (rewrite entire network architecture). CVSS treats them the same. A smart algorithm should say "fix the 5-minute one first."

Problem 5 — CVSS doesn't understand control dependencies

Some controls depend on others. You can't monitor security events (CC4.1) if you haven't enabled logging (CC7.2) first. CVSS doesn't model these dependency chains. It might tell you to fix monitoring first, which is impossible without logging.

OUR INNOVATION: CES (Compliance Efficiency Score)

CES is a new metric we created specifically for the compliance prioritization problem. It answers one question:

"Given N compliance gaps across M frameworks, what is the optimal fix sequence to reach audit-readiness in minimum time and cost?"

The Formula

$$\text{CES} = (\text{DangerScore} + \text{EfficiencyScore}) \times \text{CrossFrameworkMultiplier}$$

Component 1: DangerScore

This is the "how bad is it right now" half. Similar to CVSS but adapted for compliance gaps.

$$\text{DangerScore} = \text{Severity} \times \text{Exploitability} \times \text{DataExposure} \times \text{BlastRadius}$$

Severity (1-10): How bad is the gap?

- 10 = Data actively exposed to internet
- 7 = Missing security monitoring
- 3 = Missing documentation
- 1 = Missing optional tag

Exploitability (1-10): How easy for an attacker to take advantage?

- 10 = Public S3 bucket (anyone can access by typing the URL)
- 7 = Open SSH port (attacker needs to find it, but it's easy)
- 2 = Missing CloudWatch alarms (attacker can't exploit missing alerts)
- 1 = Missing internal documentation (not exploitable)

DataExposure (1-10): Does customer/patient data leak?

- 10 = PII/PHI directly accessible
- 7 = Database accessible but encrypted
- 3 = Logs might contain some data
- 1 = No data impact

BlastRadius (1-10): How many systems are affected?

- 10 = Root account compromised (everything is gone)
- 8 = Production database exposed
- 5 = One service affected
- 2 = One non-production resource

Component 2: EfficiencyScore

This is the part nobody else does. It measures how smart fixing this particular gap is.

$\text{EfficiencyScore} = (\text{ControlsUnlocked} \times 100) / \text{FixTimeHours}$

ControlsUnlocked: How many OTHER controls does fixing this also fix or enable?

Example dependency chains:

Enable CloudTrail (CC7.2)

- └─ Unlocks CC4.1 (can't monitor without logs)
 - └─ Unlocks CC8.1 (can't track changes without logs)
 - └─ Unlocks P1.1 (can't prove data access tracking without logs)
- = 3 controls unlocked

Enable MFA (CC6.1)

- └─ Partially fixes CC6.3 (role-based access)
- = 1 control unlocked

Write retention policy (P1.3)

- └─ Unlocks nothing
- = 0 controls unlocked

FixTimeHours: How long does this actually take to fix in AWS?

- Enable MFA: 0.1 hours (5 minutes — click a few buttons)
- Enable CloudTrail: 0.25 hours (15 minutes)
- Enable S3 encryption: 0.5 hours (30 minutes)
- Write incident response plan: 8 hours (full day of writing)
- Implement disaster recovery: 40 hours (a week of work)

Why this matters: If two controls both reduce risk by the same amount, but one takes 5 minutes and the other takes 40 hours, you should obviously fix the 5-minute one first. CVSS can't tell you this. CES can.

Component 3: CrossFrameworkMultiplier

This is the "buy one, get three free" factor.

- ×1.5 if fixing this satisfies 3 frameworks (SOC2 + ISO + HIPAA)
- ×1.2 if fixing this satisfies 2 frameworks
- ×1.0 if fixing this satisfies only 1 framework

Why this matters: If you need all three certifications, fixing a control that counts toward all three is 3x more valuable than fixing one that only counts toward SOC 2.

Full Example

28 controls are failing. Here's how CES ranks the top 3:

#1: Fix Public S3 Bucket (CC6.6) — CES: 9,750

DangerScore: $9 \times 10 \times 10 \times 7 = 6,300$

EfficiencyScore: $(1 \times 100) / 0.5 = 200$

CrossFramework: $\times 1.5$ (SOC2 CC6.6 + ISO A.13.1.1 + HIPAA §164.312(e)(1))

Fix time: 30 minutes

Score impact: 9% → 12%

#2: Enable MFA (CC6.1) — CES: 9,315

DangerScore: $9 \times 9 \times 8 \times 10 = 6,480$

EfficiencyScore: $(1 \times 100) / 0.1 = 1,000$ (only 5 mins to fix!)

CrossFramework: $\times 1.5$ (SOC2 CC6.1 + ISO A.9.4.2 + HIPAA §164.312(d))

Fix time: 5 minutes

Score impact: 12% → 15%

#3: Enable CloudTrail (CC7.2) — CES: 2,448

DangerScore: $8 \times 2 \times 3 \times 9 = 432$

EfficiencyScore: $(3 \times 100) / 0.25 = 1,200$ (unlocks 3 other controls!)

CrossFramework: $\times 1.5$ (SOC2 CC7.2 + ISO A.12.4.3 + HIPAA §164.312(b))

Fix time: 15 minutes

Score impact: 15% → 27% (because it unlocks CC4.1, CC8.1, P1.1)

Total: 50 minutes of work → 9% to 27% compliance across 3 frameworks

Compare this to doing it without CES:

- A consultant might start with the disaster recovery plan (8 hours of writing, only helps 1 control)
- Or fix CloudWatch alarms (not exploitable, low impact)
- You'd waste days on low-impact fixes while your S3 bucket is publicly leaking data

WHY CES IS NOVEL (what to tell judges)

1. **CVSS scores bugs. CES scores compliance gaps.** Different problem, different metric.
2. **No existing tool combines danger + efficiency + cross-framework coverage.** Sprinto, Vanta, Drata all just list gaps with severity labels. None calculate optimal fix order.
3. **The dependency chain analysis is genuinely new.** "Fix CloudTrail → unlocks 3 other controls" — no compliance platform models this.
4. **Fix time estimation makes it actionable.** "Fix these 3 things in 50 minutes, jump from 9% to 27%" is something a CTO can act on immediately.

5. **Cross-framework multiplier solves a real business problem.** Companies getting SOC 2 + ISO + HIPAA simultaneously can save 40% of effort by fixing overlapping controls first.
-

SUMMARY

Aspect	What we built
Problem	Compliance takes 6-12 months and ₹40+ lakhs
Solution	AI platform: zero to audit-ready in days
Frameworks	SOC 2 (33 controls) + ISO 27001 + HIPAA
Innovation	CES algorithm — optimal fix sequence across 3 frameworks
Why CES > CVSS	CVSS scores danger. CES scores danger + efficiency + cross-framework coverage + dependencies
Key feature	"Fix 5 things in 2 hours → go from 9% to 55% across all 3 frameworks"
Tech	React + FastAPI + Amazon Bedrock + boto3 + RAG
Cost to run	₹10K-28K/month
Competitor pricing	₹5-15 lakhs/year (Sprinto, Vanta)

Want to start building now, or discuss anything else?